



Air University
Mid Semester Examinations: Spring 2026

Student ID _____

Subjective Part
(To be solved on Answer Books only)

Subject: Privacy and Usable Security
Class: BSCYS
Section(s): A
Course Code: CY-455

Time Allowed: 120 Minutes
Max Marks: 50
FM's Name: Dr. Sheikh Qaisar Ayyub
FM's Signature:

INSTRUCTIONS

- Attempt responses on the answer book only.
- Nothing is to be written on the question paper.
- Rough work or writing on question paper will be considered as use of unfair means.
- Tables / calculators are allowed / not allowed.

	Q. No. 1 (CLO 1)	Marks: 25
A	Ali receives an email that appears to be from his bank asking him to urgently verify his account due to a "security issue." The email contains a link to a website that looks identical to the bank's official website. Ali clicks the link while connected to a public Wi-Fi network at a café. The website asks him to log in with his username and password. The website also requests permission to access his location data and displays a lock icon in the browser to appear trustworthy. Later, the attacker intercepts Ali's communication and stores the hashed passwords from the fake website's database. The attacker also sends a fake financial transaction request pretending to be Ali. Answer Following 1. Identify two human-factor security mistakes made by the user. 2. Describe the role of TLS (HTTPS) in secure communication and why the lock icon alone cannot guarantee a legitimate website. 3. Explain how hash functions are used to store passwords and how attackers may still attempt to recover them. 4. Identify the privacy risk related to location data in this scenario.	12.5
B	A popular mobile fitness application collects large amounts of user data such as daily step counts, heart rate, GPS location, browsing behavior inside the app, and shopping preferences for health products. The company replaces user names with IDs like User4587 before analyzing the data. However, a separate database still stores the mapping between the user ID and the real identity. The application also uses facial recognition and fingerprint authentication for login. Meanwhile, the system automatically triggers a security alert when unusual activity is detected, such as a login from a new location or abnormal usage patterns. Answer Following 1. Identify two types of behavioral data being collected by the application.	12.5

2. Determine which type of identity protection technique is used in above scenario.
3. Identify the bodily/physical privacy data used by the application and explain why protecting it is important.
4. Describe how human behavior influences cybersecurity risks in digital systems.

Q. No. 2 (CLO 2)

Marks:
25

An organization deploys a monitoring system that collects user activity logs including login attempts, password reset requests, MFA usage, link-click behavior in emails, and responses to security warnings.

Security analysts observe the following patterns in the logs:

User	MFA Enabled	Password Reuse	Phishing Link Clicked	Ignored Security Warning	Confidence Score (1-10)
A	No	Yes	Yes	Yes	9
B	Yes	No	No	No	5
C	No	Yes	No	Yes	8
D	Yes	No	No	No	6

A

Further analysis shows that some employees believe they are unlikely to be hacked, while others immediately share data when an email appears to come from a company executive requesting urgent information.

15

Answer Following

Using the above system logs and behavioral information:

1. Analyze the user behavior patterns and identify which users pose the highest cybersecurity risk.
2. Explain how cognitive biases such as overconfidence bias, optimism bias, or authority bias may influence the observed behaviors.

B

You have been hired as a Usable Security Consultant for SecureCorp. The company recently suffered a data breach because employees were using weak passwords like "Password123". To fix this, the IT department implemented the following new policies:

1. Strict Password Rules: Passwords must be at least 16 characters long, include 3 symbols, cannot reuse any of the last 10 passwords, and must be changed every 30 days.
2. Constant MFA: The system now requires a One-Time Password (OTP) every single time a user logs in, even if they are using their office desktop.
3. Aggressive Timeouts: To protect data, the system automatically logs users out after 2 minutes of inactivity.
4. Technical Error Messages: If a login fails, the system displays: "Error Code: 0x80072F8F Authentication failed".

10

Answer Following

Which security principles are these policies trying to enforce? Are they effective in achieving that goal?

1. Could the strict password rules backfire? If yes, how?
2. What are the potential risks of constant MFA, especially in a corporate environment?

3. How does the aggressive timeout policy affect confidentiality, integrity, and availability (CIA triad)?